GUIA VISUAL 022

ROOT, SUDO E ELEVAÇÃO

Colar `sudo` na frente resolve o Permission denied — e tira a rede de proteção.

022
GUIAS LINUX

ROOT É O UID 0

O kernel **pula quase toda** verificação de permissão: lê e escreve qualquer arquivo, mata qualquer processo, abre porta < 1024.

SÓ 3 LIMITES — REMOVÍVEIS

Precisa de **algum** bit x para executar · `chattr +i` trava o arquivo · SELinux/AppArmor impõem política acima. O root desfaz os três.

MENOR PRIVILÉGIO

Rode como usuário comum e eleve **só o comando**. Como root, um `rm` com um caractere a mais não pergunta nada.

ANATOMIA DE UMA REGRA DO `/ETC/SUDOERS`

QUEM	EM QUAIS MÁQUINAS	COMO QUEM	QUAIS COMANDOS
`%sudo`	`ALL`	`(ALL:ALL)`	`ALL`
O **%** marca grupo. No Kali, `kali` já é membro.	Vale em qualquer host que receba este arquivo.	Pode virar qualquer usuário e qualquer grupo.	Trocar por uma lista de binários é o coração do menor privilégio.

OS DOIS CAMINHOS PARA ELEVAR

SU — O INTERRUPTOR

- ✓ Pede a **senha do root** e abre um shell **persistente**: tudo é root até o `exit`.
- ✓ Todo admin precisa saber a mesma senha, que nunca muda.
- ✓ O log diz só "alguém virou root". No Debian/Kali a senha de root vem **bloqueada** — `su -` nem funciona.

SUDO — A CONCESSÃO

- ✓ Pede a **sua** senha, consulta a política e eleva **um comando**.
- ✓ Cache de **15 min** por terminal — `sudo -k` invalida na hora.
- ✓ `-i` = ambiente limpo de root (`/root`) · `-s` = poder de root com o **seu** ambiente.

NA PRÁTICA

```
kali@kali: ~
$ sudo -l                    # o que EU posso rodar, sem executar nada
$ sudo -u postgres psql      # sudo nao e so "virar root"
$ sudo visudo -f /etc/sudoers.d/local   # valida antes de salvar
$ sudo journalctl _COMM=sudo --no-pager | tail -1
sudo: kali : TTY=pts/1 ; PWD=/home/kali ; USER=root ; COMMAND=/usr/bin/apt update
```

RESTRINGIR O SUDO A...	...NÃO RESTRINGE NADA, PORQUE
`vim` , `less` , `man`	`:!bash` / `!bash` abre um shell de root de dentro do programa
`find`	`find . -exec bash \;` executa o que quiser
`awk` , `perl` , `python`	rodam código arbitrário por definição
`cp` , `tee` , `dd` , `tar`	sobrescrevem `/etc/sudoers` ou `/etc/passwd`

Nunca edite `/etc/sudoers` com editor comum — uma vírgula fora do lugar tranca o acesso administrativo da máquina inteira. Só `visudo`, que valida a sintaxe antes de salvar. E `NOPASSWD:` para um comando que escapa (tabela acima) é **root completo sem senha**.

RESUMO RÁPIDO

- ✓ Root é o número **0**, não o nome — e ignora os bits `rwx`.
- ✓ `su` abre shell persistente; `sudo` eleva um comando e **registra** quem foi.
- ✓ Política em `/etc/sudoers.d/`, sempre via `visudo`.
- ✓ Regra restrita só vale se nenhum comando dela rodar outro programa.

NO KALI

Root vem **bloqueado** — mantenha assim; onde um manual antigo pede `su -`, use `sudo -i`. `nmap -sS`, `tcpdump` e `aircrack-ng` pedem root porque precisam de socket *raw*: eleve **por comando**, não abra a sessão inteira como root. Em teste autorizado, `sudo -l` é o 1º reconhecimento — a maioria das escaladas nasce de um `NOPASSWD` mal escrito (ver GTFOBins). Fora de escopo escrito, é crime (Lei 12.737/2012).